

Malla de Seguridad, Privacidad y Resiliencia

Políticas de minimización de datos

El sistema aplica minimización de datos en varios puntos concretos:

- Solo datos públicos: la única fuente de información procesada son licitaciones ya publicadas oficialmente (Boletín Oficial u otras fuentes públicas de compras estatales). No se accede a información privada ni se eluden controles de acceso.
- Sin descarga de adjuntos: el Airtable Trigger tiene desactivada la opción "Download Attachments" — el sistema no descarga ni almacena archivos adjuntos innecesarios, solo el texto necesario del aviso.
- Sin datos personales de terceros: los únicos datos de contacto extraídos son los del organismo comprador (información institucional pública), nunca datos personales de individuos. Config_Empresa almacena exclusivamente datos propios de BioTecMed, no de clientes ni terceros.
- Credenciales fuera del flujo: las credenciales de Airtable, Google Gemini, Slack y Gmail se gestionan mediante el sistema de credenciales de n8n, nunca quedan expuestas en el cuerpo de los nodos ni en texto plano.
- Retención acotada: la tabla Licitaciones conserva únicamente los campos necesarios para la decisión comercial (organismo, equipo, presupuesto, prioridad); no se generan copias adicionales de la información fuera de Airtable.

Rutas de contingencia (Error Handlers)

El flujo contempla tres puntos de falla, cada uno con salida de error dedicada que actualiza el Estado en Airtable en lugar de detener el proceso silenciosamente:

Punto de falla	Configuración	Resultado
Enlace roto o inaccesible	HTTP Request con "On Error" = Continue Using Error Output	Estado = Error (probado con link roto real)
Falla del servicio de IA	Salida de error del nodo Basic LLM Chain	Estado = Error (probado con falla real: 503 "model overloaded" de Gemini durante el test de estrés)
Respuesta JSON inválida de la IA	Nodo Code con try/catch que siempre devuelve un flag explícito <code>json_invalido</code> (nunca <code>undefined</code>) + nodo IF que separa la rama	Estado = Error

Mejora aplicada a partir del test de estrés: se activó Retry On Fail en el nodo de IA (2–3 reintentos con espera entre cada uno), ya que se comprobó en producción que el proveedor externo (Gemini) puede devolver errores transitorios de saturación (503) que se resuelven solos en minutos. Esto reduce falsos "Error" causados por caídas momentáneas del servicio, no por un problema real del dato.

Puntos críticos de validación manual (Human-in-the-loop)

El sistema inserta un único pero crítico punto de control humano: antes de que se ejecute cualquier acción comercial hacia el equipo de BioTecMed (notificación por Gmail), la fila debe tener tildado manualmente el checkbox "Aprobado por humano" en Airtable.

Justificación: aunque las notificaciones (Slack y Gmail) se dirigen al propio equipo interno de BioTecMed y no a un tercero externo, el riesgo que se busca mitigar no es de exposición de datos sino de acción comercial basada en una alucinación de la IA — por ejemplo, que el modelo calcule mal la prioridad o extraiga incorrectamente el presupuesto o los requisitos técnicos, y que el sistema dispare igualmente un seguimiento comercial real sin que nadie lo haya validado. El HITL actúa como el semáforo que impide que un error de interpretación de la IA se traduzca en una decisión de negocio, evitando pérdida de tiempo del equipo comercial y, en un escenario real, un posible error frente al organismo comprador si se avanzara con información incorrecta.

La rama de "Descartada automática" (prioridad Baja) es la única decisión que la IA toma de forma completamente autónoma — y es, deliberadamente, la de menor riesgo: no implica ninguna comunicación externa ni acción comercial, solo archivar la oportunidad.

Resumen de riesgos y mitigación

Riesgo	Mitigación implementada
Alucinación de la IA en la extracción de datos	Validación de JSON estructurado + revisión humana antes de la acción comercial
Falla del proveedor de IA	Rama de error dedicada + Retry On Fail
Enlace roto o contenido inaccesible	Rama de error dedicada (HTTP Request)
Exposición de datos sensibles	No se procesan datos privados; sin descarga de adjuntos; credenciales fuera del código
Acción comercial errónea sin supervisión	Checkbox de aprobación humana obligatorio antes de Gmail